CloudDesk Technologies

Human Resources Security Policy

1. Authority, scope and proposed status

SYNTHETIC / DEMO - document control

CD-HRS-001 | Version 1.0 (wording revision). Proposed effective date: 2026-10-22. Planned next review: 2027-10-22. These dates are proposals, not an approved schedule. The Engineering Lead owns this policy and coordinates personnel security. The CTO is accountable and approves adoption. Review annually and after material personnel, service or incident changes. Approval_status: not_recorded; review_status: requires_user_review.

Status and adoption limits

CloudDesk Technologies is a fictional 75-person B2B SaaS vendor. This model-authored policy sets proposed SYNTHETIC / DEMO requirements, not operating facts. No established HR department, completed screening, delivered training or existing personnel data processing is asserted. This policy makes no certification or legal compliance claim. Human content review and recorded CTO approval are required before adoption.

Scope and responsibility

This policy covers employees, temporary personnel, contractors and vendor workers who can access company systems or information in scope. It applies from engagement through departure. Managers or assigned personnel coordinators are responsible for arranging onboarding, role changes, and employee departures. CloudDesk does not assume a dedicated HR department. System owners approve business access; authorized operators make the changes. The Engineering Lead coordinates security checks, exceptions and evidence. The CTO accepts material residual risk. Identify named substitutes and verified contact routes before adoption.

Related policy authority

The six related policies retain their authority. Access control governs identity, administrative MFA, quarterly reviews and termination revocation. Encryption governs keys and data protection. Information security governs risk and training. Incident response governs urgent containment and evidence. Backup/disaster recovery governs retained recovery dependencies. Change management governs technical changes in scope. The Engineering Lead and CTO must resolve conflicts before adoption. This policy grants no new authority for destructive actions, decryption or external communications.

Human Resources Security Policy

2. Before engagement and confidentiality

Risk-appropriate preemployment screening

Before engagement, the manager or personnel coordinator proposes checks based on the role, access sensitivity and risk. Obtain qualified jurisdiction-specific advice where needed. Establish lawful authority, required consent, permitted sources, proportionality and handling before any check. There is no universal background-check requirement and no fixed screening frequency. If a check is restricted or unsuitable, record the limitation and proposed safeguards for CTO risk review. Consent alone does not make every check lawful.

Screening decisions and records

Authorized reviewers must use relevant, verified information. Give people an appropriate opportunity to address disputed findings under applicable processes. Record the scope, authority, decision and access conditions with minimal personal information. Do not distribute raw reports. Approve retention before collection. Do not infer fitness from unsupported allegations or sensitive characteristics. This policy records no completed screening or hiring decision and makes no employment law determination.

Confidentiality and acceptable use

Before granting access, arrange appropriate confidentiality agreements or NDAs and acceptable-use acknowledgments under reviewed agreements. Explain classification, approved sharing, credential protection, phishing, secure devices and reporting. Explain continuing confidentiality after departure as applicable to the agreement. Prohibit credential sharing, unauthorized exports, personal storage of company information and secrets in code or support logs. No signed agreement or actual acknowledgment is supplied.

Contractor and vendor workforce

Before access, the engagement owner defines the sponsor, scope, start/end dates and security responsibilities. Agree confidentiality, incident reporting, access termination and information return/deletion terms. Assess vendor workforce assurance in proportion to risk. The Engineering Lead reviews the assessment; the CTO accepts material residual risk. Do not assume vendor certification or identical employee screening rules. Use named identities, approved access and expiry conditions. Verify sponsor and contract changes. Reassess critical vendors annually and after material changes or incidents under information security governance.

Human Resources Security Policy

3. Onboarding, identity and learning

Onboarding approvals and provisioned identity

The manager verifies identity and requests access with the role, start date, sponsor and required systems. System owners approve least privilege before provisioning. Authorized operators then provision the approved access. Use unique user accounts and multi-factor authentication for administrative access. Log the requester, approver, operator, permissions and completion time to document approval and provisioning. Do not copy a predecessor account or grant blanket access from a job title. Follow change management for production changes. The Engineering Lead checks missing approvals and unresolved risk before access is enabled.

Least privilege and privileged role preparation

Limit access to approved duties and the time needed. Separate privileged and ordinary work where supported. Before privileged duties, provide training on approved administration, secret handling, change approvals, incident escalation and evidence preservation. The Engineering Lead approves key grants under the encryption policy. Key administrators have no default decrypt permission. A missing prerequisite requires a documented risk assessment and approved, bounded safeguards. Do not silently self-approve.

Proposed onboarding and annual security awareness

Managers arrange security awareness at onboarding and annually thereafter. Cover phishing, credential protection, classification, acceptable use, safe sharing, personal information protection and incident reporting. Provide more guidance when roles, threats or systems change. Make the material accessible to its audience. Record overdue follow-up with the manager. These are proposed activities; no actual training delivery, completion rate or tested competence is claimed.

Training records and access readiness

The Engineering Lead tracks assigned modules, role, due date, attendance/completion, assessments where appropriate, acknowledgment and follow-up owner. Managers resolve overdue assignments. They assess temporary access restrictions with system owners based on risk. Preserve exceptions and approval evidence. This policy sets no universal training deadline or automatic sanction. Access-readiness and equipment handover checklists are proposed evidence, not completed records.

Human Resources Security Policy

4. Transfers, leave and offboarding

Transfers, leave and role changes

Managers or personnel coordinators promptly notify system owners and the Engineering Lead of transfers, leave, changed duties and return dates through verified routes. Adjust least privilege in time for the effective change, based on risk. Obtain system-owner approval for changed access and remove obsolete permissions. Assess temporary suspension during leave and reassess on return. Record approval before reactivation. Preserve necessary business records and approved holds. Leave alone does not establish misconduct.

Periodic access review every quarter

Review user access permissions every quarter, including privileged roles, dormant accounts, contractor end dates and sponsor validity. Managers confirm current duties. System owners validate entitlements. The Engineering Lead tracks removals and unresolved findings. Reconcile identity records with personnel changes. Record reviewers, decisions and verification times. Escalate overdue material risk to the CTO. These proposed reviews are not claimed completed and do not replace access changes triggered by personnel events.

Termination linkage and immediate containment

Under access_control_policy.pdf, revoke terminated employee access within 24 hours of termination at the latest. Plan revocation at the effective departure time when practicable. The 24-hour limit is not a waiting period. For urgent compromise, revoke affected access immediately under incident_response_plan.pdf. Take immediate containment action; do not delay containment for the 24-hour window, a ticket or routine personnel approval. Responders may take urgent reversible action under incident authority. The CTO retains material shutdown and residual-risk decisions. Coordinate timely contractor/vendor access removal and record its scope and verified completion.

Offboarding checklist, assets and preservation

Managers coordinate verified departure notices and asset return. System owners and authorized operators disable accounts and revoke sessions, tokens, remote access and delegated grants. Remove group memberships and rotate shared secrets where exposure requires. Record exceptions, outstanding assets and verified revocation times. Transfer necessary records and service ownership without sharing credentials. Preserve incident/evidence holds and relevant logs before disposal where safe. Do not delay urgent containment to collect evidence. Returning a device alone does not revoke access. Preserve retained backups and required key versions under recovery policies. Departure does not authorize key destruction.

Human Resources Security Policy

5. Personal information, reports and investigations

Personal information protection and approved retention

Collect personnel information only for a specified, necessary purpose with appropriate authority, transparency and consent where required. Restrict access to authorized roles with a need to know. Protect storage and transfers under the encryption policy. Document recipients and safeguards before use. This policy asserts no actual processing locations, processors or personnel datasets. Retention remains TBD pending applicable laws/contracts and approved business needs. Obtain appropriate advice and approve a schedule and holds before collection or disposal. No universal personnel retention period is set.

Reporting and proportionate response

Personnel must promptly report suspected misuse, lost assets, phishing, exposure or policy violations to the Engineering Lead through verified internal routes to be established before adoption. Contact the CTO or a designated alternate if the lead is unavailable or implicated. No live reporting service or guaranteed staffing is claimed. Limit sensitive details and exclude credentials. Managers and the CTO assess proportionate corrective or disciplinary action under applicable agreements and processes, with appropriate advice. There is no automatic sanction or predetermined employment outcome. Support good-faith reporting and avoid retaliation.

Insider-threat investigation privacy protections

Investigate credible concerns under documented authority. Define the scope and collect information proportionately. Separate facts from hypotheses. The CTO assigns an impartial authorized investigator or an alternate if there is a conflict. Obtain qualified privacy/legal advice as needed. Limit access to necessary evidence and protect confidentiality. Give people a fair opportunity to address findings under applicable processes. No blanket employee surveillance, unrestricted private-account access or presumption of guilt is authorized. Escalate suspected incidents through incident response; do not conduct informal searches.

Evidence integrity and hold decisions

Follow the incident response plan for incident IDs, custodians, collection provenance, integrity hashes where appropriate, access logs and chain-of-custody transfers. Preserve originals and analyze controlled copies. Record uncertainty and unavailable records. Coordinate incident/evidence holds with authorized decision makers and appropriate advice. Suspend routine disposal where required. Retain only justified information and review access and hold scope. The minimum 12-month retention for KMS audit logs only is not a personnel-record retention rule. No actual investigation or evidence collection is claimed.

Human Resources Security Policy

6. Exceptions, evidence and annual review

Bounded exceptions and emergency deviations

Before a planned deviation, the manager or responsible owner records the requirement, scope, reason, risk, compensating safeguards, remediation owner and expiry. The Engineering Lead assesses the request. The CTO approves or rejects it. Approved exceptions expire within 90 days and are reviewed monthly. Renewal requires fresh assessment and approval. Expired approval cannot authorize access. Emergency deviations require an incident record and next-business-day CTO review. Do not delay urgent containment. An exception cannot authorize unlawful screening, erase applicable obligations or silently extend the original 24-hour termination requirement. No active exception is asserted.

Proposed evidence types

Proposed personnel records include role risk assessments, lawful screening and consent decisions where applicable, confidentiality agreements, acceptable-use acknowledgments, and training assignments, completion and follow-up records. Proposed access and security evidence includes onboarding access approvals, identity/MFA checks, transfer/leave tickets, quarterly reviews, offboarding revocation times and asset returns. It also includes contractor sponsor/end-date reviews, authorized investigation records, retention/hold decisions, exceptions and policy review feedback. These are proposed evidence types, not actual personnel files or evidence of operating controls. Minimize sensitive contents and assign restricted custodians.

Governance review and dependencies

The Engineering Lead checks personnel-security gaps and corrective actions with managers and system owners. Escalate material residual risk to the CTO. Review this policy at least annually and after significant incidents or material role, vendor or service changes. Preserve encryption approvals and recovery holds. Technical changes in scope follow CD-CHG-001. Align training with onboarding and annual awareness in CD-ISP-001. Keep the original quarterly access-review requirement. This policy adds no screening cadence, retention period or recovery target.

Human adoption gate

Before adoption, human reviewers must validate jurisdiction and consent constraints, contracts, personnel coordination and substitutes. Validate reporting routes, proportionate investigations, training plans, retention schedules and all six related policies. Record conflicts, reviewer feedback and CTO approval. Approval_status: not_recorded; review_status: requires_user_review. This proposed policy does not provide evidence that CloudDesk has implemented or tested these controls.